UNIVERSIDAD DEL VALLE
FACULTAD DE INGENIERÍA — ESCUELA DE SISTEMAS
MAESTRÍA EN DESARROLLO DE APLICACIONES INTELIGENTES
SEGURIDAD EN EL DESARROLLO DE APLICACIONES

Punto 4. Modelado de amenazas mediante el marco de las cuatro preguntas

Módulo Tres: tareas de equipo púrpura para sistemas basados en IA

Miguel Ángel Rincón — 2502619-7729
Maria Paula Jimenez I — 2507713-7729
David Steven Duran Vallejo — 2508228-7729

> **Alcance.** Este documento es el modelado de amenazas del Módulo Tres. No sustituye el Punto 4 del Taller 2, que comparó cobertura normativa de NIST CSF 2.0 frente a IA. Aquí se responden las cuatro preguntas del marco [1] con el caso de uso del Punto 1, las técnicas ATLAS del Punto 2 y la evidencia púrpura del Punto 3. Las acciones defensivas se ubican en Identificar, Proteger y Detectar [2].

4.1. ¿Qué estamos construyendo?

FinanCali S.A.S. es una fintech colombiana ficticia de aproximadamente 50 personas cuya operación digital depende de la originación de crédito de consumo. El objeto de análisis es el scoring semiautónomo que asigna un puntaje de 0 a 100 y lo traduce en rechazo (< 40), revisión humana (40–69) o aprobación automática (≥ 70). El modelo no otorga crédito por sí solo: la aprobación automática es una decisión de negocio asistida por el score, y la cola de revisión es el control humano residual [3].

El sistema de trabajo de este módulo no es una plataforma bancaria, sino un prototipo local equivalente en tres dimensiones exigidas por el enunciado: tipo de modelo, superficie de ataque y naturaleza de los datos. Implementa un `GradientBoostingClassifier` sobre 4.000 registros sintéticos, una API de inferencia y una interfaz web. El dataset no contiene nombre, documento, ubicación, sexo, edad ni nacionalidad. El prototipo no se conecta a centrales de riesgo ni produce efectos sobre solicitantes reales.

Tabla 1. Componentes que entran al modelado

Componente	Qué es en el laboratorio	Qué representaría en FinanCali
Datos de entrenamiento	Generador sintético determinista, hash SHA-256.	Histórico de originación y etiquetas de resultado crediticio.
Pipeline y artefacto	Preparación + `GradientBoostingClassifier` versionado.	Entrenamiento por lotes, promoción de modelos y rollback.
Contrato de inferencia	`POST /api/score` (defendido) y `/api/lab/vulnerable-score` (laboratorio).	Microservicio interno consumido por la aplicación de originación.
Variables de entrada	Declaradas por el solicitante; confiables vía perfil de laboratorio; `debt_ratio` derivado.	Formulario + consulta a buró + cálculos de política crediticia.
Salida	Score, probabilidad, decisión, versión, códigos de alerta.	Decisión asistida, explicación para analista y registro de auditoría.

Lo que se está construyendo, en términos de amenaza, es un **límite de confianza**: un canal que recibe datos del solicitante, los combina con señales que deberían ser ajenas a ese canal, y dispara una decisión con impacto financiero. El Taller 1 ya había identificado activos (datos, modelo, API, credenciales, nube) y una madurez inicial baja. El Módulo Dos eligió NIST CSF 2.0 y dejó abiertas las amenazas especializadas contra el modelo. Este Punto 4 cierra ese hueco con evidencia, no con un nuevo marco.

4.2. ¿Qué puede salir mal?

La respuesta no parte de una lista genérica de riesgos de inteligencia artificial. Parte de las tres técnicas de madurez *Realized* que el Punto 2 encontró factibles sobre componentes que existen [4]:

Tabla 2. Amenazas priorizadas (MITRE ATLAS 2026.09)

Técnica	Qué puede salir mal	Actor y acceso	Impacto sobre FinanCali
AML.T0043.003 Manual Modification 96/100 · ejercida en Punto 3	El solicitante o un intermediario altera variables confiables o derivadas hasta cruzar el umbral de aprobación.	Acceso ordinario al canal de solicitud. No necesita el modelo ni el dataset.	Aprobación indebida, elusión de revisión humana y pérdida directa.
AML.T0020 Training Data Poisoning 88/100 · no ejercida	Alguien con escritura sobre el histórico o el pipeline inserta o relabela muestras para sesgar el modelo publicado.	Privilegio interno, cuenta técnica o fuente externa incorporada al entrenamiento.	Errores persistentes, sesgo dirigido y dificultad de diagnóstico tras el despliegue.
AML.T0024.002 Extract AI Model 81/100 · no ejercida	Consultas repetidas a la API permiten entrenar un sustituto y ensayar evasiones fuera de línea.	Caja negra sobre el endpoint de inferencia. En el laboratorio no hay autenticación ni cuota.	Pérdida de propiedad del modelo y preparación silenciosa de AML.T0043.003.

El Punto 3 convirtió la primera amenaza de hipótesis en hecho observable: 24 de 24 solicitudes de revisión pasaron a aprobación cuando el cliente controló indicador externo, moras, historia y `debt_ratio`. El incremento medio fue de 45,25 puntos. Eso descarta dos lecturas erróneas frecuentes. Primera: “el modelo tabular es demasiado simple para atacarlo”. Segunda: “basta validar rangos”. Los valores adversarios eran plausibles; el fallo fue de procedencia.

Otras técnicas se consideraron y se dejaron fuera con motivo: membresía e inversión del modelo son *Feasible* y el dataset es sintético; la optimización de caja negra es *Demonstrated*; prompt injection no aplica a un clasificador tabular. La denegación de servicio sobre el modelo aporta poco porque el artefacto es pequeño. El modelado no afirma que esas técnicas sean imposibles; afirma que no son las más pertinentes para este sistema en este momento.

4.3. ¿Qué vamos a hacer al respecto?

Cada amenaza priorizada se traduce en acciones de Identificar (saber qué hay que proteger y de dónde viene cada dato), Proteger (impedir el abuso en el borde o en el pipeline) y Detectar (observar el intento o su efecto). Gobernar, Responder y Recuperar siguen vigentes desde el Módulo Dos, pero este módulo pide explicitar ID, PR y DE [2].

AML.T0043.003 — Modificación manual de entradas

Tabla 3. Acciones para la técnica ejercida

Función	Resultado CSF 2.0	Acción concreta en FinanCali / laboratorio
Identificar	ID.AM activos; ID.RA riesgos	Inventariar el endpoint de inferencia y clasificar cada variable como declarada, derivada o proveniente de fuente confiable. El Punto 2 y el diccionario del prototipo ya hacen esa partición.
Proteger	PR.DS datos; PR.AA acceso	Contrato público sin campos confiables (`ApplicantProvidedData`, `extra="forbid"`). Resolver historia, moras e indicador en servidor. Calcular `debt_ratio` a partir de obligaciones e ingreso. En producción, ligar esa resolución a identidad autenticada y a la consulta contractual con el buró —el selector `trusted_profile_id` solo vale para el laboratorio.
Detectar	DE.CM monitoreo; DE.AE eventos	Registrar `blocked_input_manipulation`, contar `blocked_manipulations` y comparar con Evidently la distribución de campos confiables. Un lote con indicador 100 y mora 0 de forma sistemática debe abrir revisión, no aprobación.

La evidencia del Punto 3 muestra que Proteger en el contrato es el control que impide la decisión indebida. Detectar llega tarde si la ruta vulnerable ya respondió 200. Por eso la detección se coloca detrás del rechazo, no como sustituto.

AML.T0020 — Envenenamiento del entrenamiento

Tabla 4. Acciones para la amenaza persistente no ejercida

Función	Resultado CSF 2.0	Acción concreta
Identificar	ID.AM; ID.RA	Inventario del dataset, semilla, función generadora o fuente histórica, etiqueta objetivo y ventana temporal. Conservar hash SHA-256 de cada versión autorizada —el laboratorio ya expone ese hash.
Proteger	PR.AA; PR.PS	Escritura mínima sobre datos y pipeline, separación de quien etiqueta y quien despliega, revisión de cambios y bloqueo de reentrenamiento desde la API de inferencia (hoy no existe ese endpoint, y debe seguir sin existir).
Detectar	DE.CM	Comparar ROC AUC, F1, Brier y tasa de aprobación por segmento contra la línea base antes de publicar una versión. Una mejora global con aprobación anómala en un perfil es señal de envenenamiento dirigido, no de “mejor desempeño”.

AML.T0024.002 — Extracción del modelo

Tabla 5. Acciones para la amenaza de confidencialidad no ejercida

Función	Resultado CSF 2.0	Acción concreta
Identificar	ID.AM	Inventariar quién puede llamar a `/api/score`, qué campos de salida son indispensables para el negocio y qué metadatos (probabilidad completa, versión, sensibilidad local) sobran para un cliente externo.
Proteger	PR.AA	Autenticación de servicio, autorización de mínimo privilegio, cuotas y rate limiting. En producción, no exponer la ruta de laboratorio. Reducir precisión de la probabilidad si el analista no la necesita a cuatro decimales.
Detectar	DE.CM; DE.AE	Alertar consultas sistemáticas, cobertura amplia del espacio de entradas y repetición de umbrales. Ese patrón es distinto de una originación legítima y precede a un modelo sustituto.

```
DECISIÓN DE DISEÑO DESPUÉS DE LOS PUNTOS 2 Y 3

1. La API pública de scoring no recibe campos confiables ni derivados.
2. La ruta vulnerable permanece etiquetada como laboratorio y no se documenta
   como canal de negocio.
3. Todo intento de inyectar esos campos genera 422 y un evento auditable.
4. AML.T0020 y AML.T0024.002 se tratan como residuales: hay acciones ID/PR/DE
   definidas, pero aún no hay prueba púrpura equivalente.
5. El selector de perfil confiable no se presenta como control de identidad.
```

4.4. ¿Hicimos un buen trabajo?

Esta pregunta se responde con la evaluación práctica, no con la coherencia narrativa del documento. El Punto 3 permite tres juicios distintos.

Qué sí quedó demostrado

- El modelado acertó al priorizar AML.T0043.003: era la técnica más accesible y, al probarla, desplazó el 100 % de las decisiones de revisión a aprobación. Un análisis que hubiera empezado por envenenamiento habría sido más espectacular y menos representativo del adversario más probable.
- El control propuesto en el Punto 2 no se quedó en recomendación. El contrato defendido rechazó 24 de 24 payloads adversarios y aceptó una petición válida. El criterio de aprobación se cumplió.
- La herramienta no fue cosmética. Evidently midió deriva en las cuatro columnas atacadas (share = 1,00). Eso articula ofensiva (el ataque cambió la población de entrada) y defensa (el mismo monitor serviría en operación).

Dónde el análisis todavía es incompleto

Tabla 6. Calidad del modelado a la luz del Punto 3

Afirmación previa	Qué dice ahora la evidencia
"Validar rangos no basta."	Confirmado: los valores adversarios eran legales respecto del dominio y aun así cruzaron el umbral.
"Separar variables por procedencia contiene AML.T0043.003."	Confirmado para el contrato HTTP. No confirmado para un selector de perfil que el usuario aún elige a mano.
"El envenenamiento es la amenaza de mayor impacto persistente."	Sigue siendo un juicio de factibilidad, no un resultado empírico: no se ejecutó AML.T0020.
"La API sin cuota permite extracción."	Plausible y no cerrado. El laboratorio sigue devolviendo probabilidad y versión, y no limita consultas.
"El prototipo equivale al caso de uso."	Equivale en tipo de modelo, superficie y naturaleza de datos. No equivale en identidad, buró real, autenticación ni pérdida financiera.

Juicio final. El trabajo es suficiente para la amenaza que se eligió ejercer y honesto sobre las que no. No es un modelado "completo" del scoring de FinanCali: faltan prueba de envenenamiento, prueba de extracción, enlace real de identidad y los controles de Gobernar/Responder/Recuperar que el Taller 2 ya había dejado abiertos (equidad, explicación utilizable, apelación, retiro del dato). Presentar el rechazo HTTP 422 como cierre de todo el riesgo de IA sería un mal trabajo. Presentarlo como evidencia de que la frontera de confianza es el control decisivo para AML.T0043.003 sí lo es.

Riesgo residual aceptado para el laboratorio

1. La ruta `/api/lab/vulnerable-score` permanece para reproducir el ejercicio; en cualquier uso fuera del curso debe eliminarse.
2. `trusted_profile_id` no está ligado a una identidad: un usuario del laboratorio aún puede escoger el perfil `stable`.
3. No hay autenticación, cuota ni cifrado; no se deben extraer conclusiones de resistencia a AML.T0024.002.
4. Evidently detecta cambio de distribución, no atribuye dolo. Un analista humano sigue siendo necesario para interpretar la alerta.

Síntesis de las cuatro preguntas. Estamos construyendo un scoring tabular semiautónomo cuya decisión depende de datos que no deberían viajar en el mismo canal que la declaración del solicitante. Puede salir mal, de forma ya observada, la modificación manual de esas entradas; y de forma pertinente aunque no ejercida, el envenenamiento y la extracción. Vamos a separar procedencia en el contrato, resolver señales confiables en servidor, hashear el dataset, restringir el reentrenamiento y monitorear deriva e intentos bloqueados. Hicimos un buen trabajo sobre AML.T0043.003 y un trabajo todavía hipotético sobre las otras dos técnicas: esa diferencia queda explícita para no confundir un control verificado con un sistema seguro.

Referencias

1. Shostack, A. *Threat Modeling: Designing for Security*. El marco de las cuatro preguntas. Wiley, 2014. Recogido en el material del Módulo Tres, Universidad del Valle, 2026-II.
2. National Institute of Standards and Technology. *The NIST Cybersecurity Framework (CSF) 2.0*. NIST CSWP 29, 2024. Funciones Identificar, Proteger y Detectar.
3. FinanCali S.A.S. *Punto 1 — Definición del caso de uso de IA*. Artefacto académico del Módulo Tres.
4. FinanCali S.A.S. *Punto 2 — Análisis de factibilidad con MITRE ATLAS* y *Punto 3 — Evaluación práctica de equipo púrpura*.
5. MITRE ATLAS. *ATLAS Data 2026.09*. Técnicas AML.T0043.003, AML.T0020 y AML.T0024.002.
6. Universidad del Valle. *Módulo Tres: Tareas de equipo púrpura para sistemas basados en IA*. Seguridad en el Desarrollo de Aplicaciones, 2026-II.